

(c) Narrativa explicativa GQM + PRAGMATIC para indicadores ISO/IEC 42001 – Ciberseguridad de IA

1. Por qué no basta con “tener métricas”

La experiencia en seguridad y en IA enseña una lección recurrente: es perfectamente posible ahogar a una organización en métricas irrelevantes. Gráficos sofisticados, dashboards multicolor y KPIs ingeniosos pueden coexistir con una realidad incómoda: los incidentes siguen creciendo, las decisiones clave no cambian y nadie sabe muy bien qué hacer con todos esos números.

El objetivo de combinar GQM con PRAGMATIC es precisamente evitar esa trampa. GQM fuerza a empezar por los objetivos –qué queremos conseguir a nivel nacional o corporativo– y a formular las preguntas que realmente importan. PRAGMATIC, por su parte, actúa como un filtro de calidad para cada métrica concreta: ¿predice algo útil?, ¿es relevante?, ¿se puede actuar sobre ella?, ¿es honesta, comprensible, precisa y coste-efectiva?

2. De los objetivos nacionales a los datos del SIEM

ISO/IEC 42001 insiste en que un sistema de gestión de IA debe estar alineado con el contexto externo, incluyendo regulaciones, estrategias nacionales y expectativas de las partes interesadas. Cuando se habla de España, esto significa, entre otras cosas, conectar los indicadores técnicos de los modelos y los SOC con objetivos como:

- Reducir la frecuencia y el impacto de incidentes de ciberseguridad relacionados con IA en sectores críticos.
- Asegurar que los sistemas de IA que afectan a derechos de las personas tienen controles adecuados de datos, supervisión humana y trazabilidad.
- Demostrar diligencia razonable frente a marcos como el EU AI Act, el ENS y las estrategias nacionales digitales.

El enfoque GQM ayuda a descomponer estos fines en preguntas más manejables: ¿cuántos sistemas de IA tenemos realmente en producción?, ¿qué porcentaje está cubierto por telemetría de seguridad?, ¿cuánto tardamos en detectar y contener un incidente de IA?, ¿qué parte de nuestro riesgo viene de terceros?, ¿está la gente preparada para gestionar estas amenazas?

Sólo entonces tiene sentido hablar de métricas: número de sistemas inventariados, tiempos medios, porcentajes de cobertura, índices de madurez, estimaciones de costes. La gracia está en poder trazar una línea clara desde un indicador concreto –por ejemplo, el porcentaje de modelos con detección de deriva activa– hasta la pregunta que responde y el objetivo al que sirve.

3. PRAGMATIC: cribado de métricas para adultos responsables

El acrónimo PRAGMATIC resume nueve preguntas incómodas que toda métrica debería ser capaz de contestar:

- ¿Ayuda a prever algo (Predictivo) o sólo consuela mirando al pasado?
- ¿Importa realmente para los riesgos y objetivos que nos juegan el futuro (Relevante)?
- ¿Puede provocar una acción razonable (Accionable) o se limita a decorar informes?
- ¿Refleja lo que ocurre sin dar incentivos fuertes a la manipulación (Genuino)?
- ¿La entienden quienes deben tomar decisiones (Significativo)?
- ¿Está definida de manera que dos personas distintas lleguen al mismo número (Preciso)?
- ¿Llega a tiempo como para influir en decisiones (Oportuno)?
- ¿Aporta algo que no estemos midiendo ya por otro lado (Independiente)?
- ¿El coste de medirla merece la pena (Rentable)?

Cuando se aplican estos criterios a los indicadores de ISO 42001, algunas métricas emergen como estrellas naturales (tiempos de detección y remediación, incidentes de IA, cobertura de inventario, formación de personal clave). Otras requieren más cariño metodológico (especialmente el ROI, que tiende a la poesía contable si no se maneja con cautela).

4. Evitar la ilusión de control numérico

Un riesgo sutil del entusiasmo por las métricas es la ilusión de control: creer que, porque algo se puede representar con dos decimales en un gráfico, está bajo control. En ciberseguridad de IA, esto es particularmente peligroso: modelos complejos, cadenas de suministro opacas y adversarios creativos no siempre se dejan capturar en un KPI amable.

Por eso el marco insiste en dos ideas:

- GQM debe mantenerse vivo: los objetivos y las preguntas pueden cambiar a medida que evoluciona el uso de IA y el paisaje de amenazas.
- PRAGMATIC no es un sello permanente: la evaluación de una métrica puede mejorar (o empeorar) según maduren los procesos, la telemetría y la cultura de reporte.

La métrica “número de incidentes de IA” puede ser poco genuina (G bajo) en una organización que apenas tiene capacidad de detección; años después, con mejor telemetría y cultura, puede convertirse en un indicador mucho más honesto y útil.

5. Cómo usar esta narrativa con la alta dirección

En foros ejecutivos, la combinación GQM + PRAGMATIC permite articular un discurso razonablemente serio y, a la vez, accesible:

1. "Estos son nuestros objetivos en IA segura" (reducir incidentes, cumplir normativa, proteger reputación, habilitar innovación responsable).
2. "Estas son las preguntas que necesitamos responder para saber si los estamos cumpliendo" (¿qué tenemos, qué riesgo tenemos, qué nos está pasando, cómo de rápido reaccionamos, quién nos puede fallar, quién sabe gestionar todo esto?).
3. "Estas son las métricas que proponemos" y, para cada una, una pequeña ficha PRAGMATIC que explique por qué merece un lugar en el escaso espacio mental de la dirección.

De este modo, el debate se desplaza de "quiero más dashboards" a "qué indicadores realmente nos ayudan a tomar decisiones difíciles". ISO/IEC 42001 pide precisamente eso: no coleccionar gráficos, sino demostrar que la gestión de IA se basa en evidencias y conduce a mejoras tangibles.

6. Límite sano: pocas métricas, bien cuidadas

El marco GQM + PRAGMATIC no invita a multiplicar indicadores, sino a hacer selección natural. Una buena práctica habitual es:

- Mantener un conjunto reducido de métricas estratégicas (10–15 a nivel nacional o corporativo), todas con su ficha GQM y valoración PRAGMATIC.
- Complementarlas con métricas operativas específicas por dominio (datos, incidentes, terceros, cultura) que se usen en equipos técnicos y no necesariamente suban a consejo.
- Revisar anualmente qué métricas siguen siendo útiles y cuáles han dejado de aportar valor.

Si una métrica no supera, por ejemplo, un umbral mínimo en Relevancia, Accionabilidad o Rentabilidad, quizás haya llegado el momento de dejarla ir. No hay nada más poco pragmático que mantener medidores que nadie mira o que nadie sabe cómo usar.